Disciplina: Segurança da Informação
Prof.: Gilmar Gomes do Nascimento

Nome: _____

INSTITUTO FEDERAL
Tocantins

---

1. O que é uma **sessão** em aplicações web? Explique o papel do cookie de sessão e por que ele é usado em vez de enviar usuário e senha em cada requisição.

2. O que é **entropia de token**? Por que ela é fundamental para a segurança de tokens de sessão? O que acontece se um token tiver baixa entropia?

3. Explique o que é a flag `HttpOnly` em cookies. Qual ataque ela previne e por quê?

4. Explique o que é a flag `Secure` em cookies. Em que cenário a ausência dessa flag representa risco?

5. Uma aplicação gera tokens de sessão usando apenas `timestamp` em segundos. Explique por que isso é inseguro e como um atacante poderia explorar essa falha.

6. O que significa o princípio **Never Trust the Client** (nunca confie no cliente)? Dê um exemplo prático de falha causada pela violação desse princípio.

7. Explique o conceito de **Source of Truth** (fonte da verdade) no contexto de segurança de aplicações. Por que o servidor deve ser sempre a fonte da verdade?

8. O que é **fuzzing** no contexto de testes de segurança? Qual o objetivo dessa técnica?

9. Explique a diferença entre os três tipos de ataque do Burp Intruder:

   - **Sniper**
   - **Pitchfork**
   - **Cluster Bomb**